

Beveiligings- en AVG-rapport

ZWB Cycling-platform

Datum: 31 mei 2026

Scope: Next.js 15 + Supabase, gehost op Netlify

Toetsing: OWASP Top-10 + AVG/GDPR

1. Managementsamenvatting	2
2. Scope & methode	2
3. Architectuur & dataclassificatie	2
4. Technische bevindingen	2
5. AVG/GDPR-conformiteit.....	4
5.1 Verwerkingsregister (RoPA, beknopt).....	4
5.2 DPIA-notitie (locatie + gezondheid)	5
5.3 Cookies	5
6. Risicomatrix & restant-backlog	5
7. Verificatie (testbewijs)	5

1. Managementsamenvatting

Het ZWB-platform staat er qua beveiliging goed voor. De basis is solide: strikte toegangsbeveiliging op rij-niveau (RLS) op vrijwel alle tabellen, een consistent rollen-/rechtenmodel, een goedkeurings-gate voor nieuwe leden, veilige (gehashte) opslag van live-tracking-tokens en automatische opruiming van locatiegegevens.

Tijdens de doorlichting zijn zeven technische aandachtspunten en vijf AVG-tekortkomingen gevonden. Alle zijn in deze ronde aangepakt. De belangrijkste verbeteringen:

- Bescherming tegen misbruik van de externe scrapers (SSRF).
- Geheimen (Strava-tokens, intervals.icu-keys) worden nu **versleuteld** opgeslagen.
- Beveiligings-headers en een privacy-conform fundament (privacyverklaring, toestemming, data-export en account-verwijdering).

Twee acties liggen nog bij de beheerder: het zetten van de encryptiesleutel-env (TOKEN_ENCRYPTION_KEY) plus eenmalige backfill, en het uitrollen van de nieuwe databasemigraties (0060–0063). NIS2 is niet van toepassing op een sportclub; er zijn geen tracking-cookies, dus een cookiebanner is niet nodig.

Eindoordeel: na uitrol van deze ronde voldoet het platform aan de gangbare Europese eisen voor een vereniging die persoonsgegevens verwerkt.

2. Scope & methode

Onderzocht met een OWASP-Top-10-bril en getoetst aan de relevante AVG-artikelen: authenticatie & autorisatie, omgang met geheimen en persoonsgegevens, het webaanvalsoppervlak (XSS, SSRF, invoervalidatie, uploads, headers, rate limiting) en AVG-conformiteit (grondslagen, rechten, bewaartermijnen, verwerkers).

Buiten scope: externe penetratietest, audit van de Supabase-/Netlify-infrastructuur zelf, en NIS2 (niet van toepassing).

3. Architectuur & dataclassificatie

Account/profiel	naam, e-mail, foto, regio, FTP, gewicht	Normaal–verhoogd
Gezondheid (opt-in)	rusthartslag, HRV, slaap, readiness	Bijzonder/verhoogd
Locatie (opt-in)	live GPS-positie, snelheid, hoogte	Verhoogd
Koppelingen	Strava-tokens, intervals.icu-API-key	Geheim
Door leden geplaatst	chat, ritverslagen, reacties, foto's, RSVP	Normaal

Toegang tot gezondheids- en locatiegegevens is beperkt tot de betrokkene zelf (en een door hem/haar aangewezen trainer). Beide stromen zijn opt-in.

4. Technische bevindingen

F1	SSRF — scrapers/RSS haalden gebruikers-URL's op zonder bescherming tegen interne adressen	Hoog	Opgelost
F2	Geheimen in logs — auth-callback logde login-code/token_hash	Hoog	Opgelost
F3	Geen security headers (CSP, HSTS, X-Frame-Options, ...)	Midden	Opgelost
F4	Tokens/keys plaintext at rest in de database	Hoog	Opgelost (sleutel + backfill)
F5	Nauwelijks rate limiting op login/signup/chat/scraper	Midden	Opgelost
F6	Uploads zonder server-side MIME/grootte-limiet	Laag–midden	Opgelost
F7	Geen audit-log op gevoelige wijzigingen	Midden	Opgelost

F1 — SSRF-bescherming

Nieuwe helper `safe-fetch.ts` weigert verzoeken naar `loopback/private/link-local/metadata`-adressen. Ingebouwd in de uitslag-scraper, `team-results-sync` en `RSS-feed`. Resterend risico: laag.

F2 — Log-hygiëne

De `queryparam-dump` in de `auth-callback` is verwijderd; geheime eenmalige tokens komen niet meer in de serverlogs.

F3 — Security headers + CSP

`next.config.ts` zet nu HSTS, `nosniff`, `X-Frame-Options DENY`, `Referrer-Policy` en `Permissions-Policy`. De `Content-Security-Policy` draait eerst als `Report-Only` zodat embeds en styles niet breken; na observatie kan die worden afgedwongen.

F4 — Versleuteling at rest

Strava-tokens en `intervals.icu`-keys worden versleuteld met AES-256-GCM (sleutel uit `TOKEN_ENCRYPTION_KEY`). Ontsleuteling gebeurt centraal op de plek van gebruik. Bestaande plaintext blijft werken tot de eenmalige backfill is gedraaid. Actie: sleutel zetten + backfill.

F5 — Rate limiting

Atomaire DB-teller + helper, toegepast op `login/signup/magic-link` (per IP), publieke chat-POST (per IP) en de scraper (per gebruiker/dag). Bewust fail-open zodat een storing de normale werking niet blokkeert.

F6 — Upload-hardening

MIME-allowlists (alleen afbeeldingen) en grootte-limieten op de storage-buckets.

F7 — Audit-log

Een `audit_log` met triggers op rol-permissie- en profiel-machtswijzigingen (`is_admin/is_approved`). Alleen leesbaar voor rolbeheerders.

Reeds in orde (geen actie)

- XSS: Markdown-rendering negeert ruwe HTML; geen `dangerouslySetInnerHTML`.
- SQL-injectie: alle queries via de geparametriseerde Supabase-builder.

- Cron/webhooks: Bearer-secret-validatie.
- Live-tracking-tokens: gehasht opgeslagen (SHA-256).

5. AVG/GDPR-conformiteit

Rechtmatigheid & toestemming (6, 7, 9)	Opgelost	Verplichte akkoord-checkbox bij registratie; privacy_accepted_at vastgelegd; gezondheid/locatie expliciet opt-in.
Transparantie (13/14)	Opgelost	Publieke privacyverklaring op /privacy.
Inzage & dataportabiliteit (15/20)	Opgelost	'Download mijn gegevens' → /api/account/export (JSON).
Recht op vergetelheid (17)	Opgelost	Self-service account-verwijdering met bevestiging.
Bewaarbeperking (5)	Opgelost	Live-posities 30 dagen; chat >1 jaar opgeruimd; koppel-data bij ontkoppelen.
Beveiliging (32)	Opgelost	RLS, encryptie at rest, headers, rate limiting, audit-log.
Privacy by design/default (25)	Aanwezig	Opt-in voor gevoelige data, minimale zichtbaarheid standaard.
Verwerkingsregister (30)	Dit rapport	Zie 5.1.

5.1 Verwerkingsregister (RoPA, beknopt)

Supabase	Database, auth, opslag	Alle platformdata
Netlify	Hosting webapplicatie	Verkeer/logs
Strava	Activiteiten (op koppeling)	Ritten, tokens
intervals.icu	Training/wellness (op koppeling)	Trainings-/gezondheidsdata
OpenAI	Concept-trainingsschema's	Trainingscontext
Mapbox/OSM	Kaarten	Route-/GPX-coördinaten
Resend	Transactionele e-mail	E-mailadres
Mollie	Eventuele betalingen	Betaalgegevens
Web-push	Notificaties	Push-subscription
YouTube/Spotify	Media-embeds	— (alleen weergave)

Actiepunt voor het bestuur: sluit waar nodig een verwerkersovereenkomst met deze partijen en controleer het EU-/adequaate dataverwerkingsniveau.

5.2 DPIA-notitie (locatie + gezondheid)

Locatie- en gezondheidsgegevens zijn extra gevoelig. Aanwezige mitigaties: strikte opt-in, beperkte zichtbaarheid (alleen betrokkene + eventueel trainer), automatische retentie (30 dagen voor posities), RLS en encryptie van koppel-tokens. Het restrisico is laag en proportioneel voor het doel (samen fietsen, trainingsbegeleiding). Een volledige DPIA wordt aanbevolen als het ledenaantal of de verwerkingsschaal sterk groeit.

5.3 Cookies

Alleen functionele auth-cookies; geen tracking/advertenties → geen cookiebanner vereist (wel benoemd in de privacyverklaring).

6. Risicomatrix & restant-backlog

Na deze ronde resteren alleen lage restrisico's en beheer-acties:

1. Beheer-actie: TOKEN_ENCRYPTION_KEY zetten + /api/admin/encrypt-secrets eenmalig draaien; migraties 0060–0063 uitrollen.
2. Later (optioneel): CSP van Report-Only naar afdwingend zetten na observatie; nonces i.p.v. unsafe-inline.
3. Later (optioneel): plaintext-tokenkolommen droppen nadat de backfill is bevestigd.
4. Later (optioneel): verwerkersovereenkomsten formeel vastleggen.

7. Verificatie (testbewijs)

- Typecheck (tsc) schoon na elke wijziging.
- SSRF: een scrape-URL naar 127.0.0.1 of 169.254.169.254 wordt geweigerd; echte timing-URL's blijven werken.
- Beveiligings-headers zichtbaar in de respons (HSTS/nosniff/frame-deny + CSP-Report-Only).
- Nieuwe Strava-/intervals-koppeling wordt versleuteld opgeslagen (prefix enc:v1:); sync blijft werken.
- Rate limiting geeft 429 bij te veel pogingen.
- /privacy publiek bereikbaar; registreren vereist akkoord.
- 'Download mijn gegevens' levert volledige JSON; account-verwijderen wist auth + profieldata.